# Microsoft Purview NIST 800-53 Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

# Contents


Executive Summary — Microsoft Purview NIST 800-53 Compliance Program 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 6

The bottom line . . . 6

1. Solution Overview — Microsoft Purview NIST 800-53 Compliance Program 6

What this solution is . . . 6

What it does — and does not — decide . . . 6

Why this matters . . . 7

How it works . . . 7

The control families this solution addresses in Purview . . . 8

What you can control . . . 8

Limitations (be honest with buyers) . . . 9

Naming convention (used in every doc and script) . . . 9

The standard deployment model . . . 10

2. Requirements Guide — Microsoft Purview NIST 800-53 Compliance Program 10

2.1 Compliance licensing for the NIST 800-53 template and supporting controls . . . 10

2.2 Purview roles (least-privilege) for Compliance Manager and the supporting controls . . . 11

2.3 Security & Compliance PowerShell + Exchange Online PowerShell + Graph . . . 11

2.4 In-scope system boundary, data, and workloads (from the security/AO function) . . . 11

2.5 Control applicability / tailoring baseline (deferred to compliance/security) . . . 11

2.6 Unified audit logging and audit-evidence retention requirements (AU family) . . . 12

2.7 A pilot scope and change control (simulation/test first) . . . 12

2.8 Evidence-handling and assessment-package requirements (from the assessor/AO) . . . 12

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 13

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 14

5. Compliance, records, privacy & legal stakeholders . . . 14

6. A pilot scope and change control . . . 14

3. Implementation Guide — Microsoft Purview NIST 800-53 Compliance Program 15

Step 1 — Assess licensing, roles, and current Purview control posture (Assess) . . . 15

Step 2 — Create the Compliance Manager assessment (Assess → Design) . . . 15
Step 3 — Build the control-to-Purview map (Design) . . . 16
Step 4 — Configure the AU family: audit + audit-evidence retention (Configure) . . . 16
Step 5 — Configure the SC/MP/SI supporting DLP control in SIMULATION (Configure → Pilot) . . . 17
Step 6 — Configure the AC/SC label & encryption evidence (Configure) . . . 17
Step 7 — Validate control evidence exists per family (Validate) . . . 17
Step 8 — Produce the control-evidence report / package (Validate → Evidence) . . . 18
Step 9 — Expand to enforcement and maintain (Expand) . . . 18
5. Testing & Validation — Microsoft Purview NIST 800-53 Compliance Program 18
Gate 1 — Licensing, roles, and toolchain are in place . . . 19
Gate 2 — Compliance Manager NIST 800-53 assessment exists . . . 19
Gate 3 — Unified audit logging on (AU family foundation) . . . 19
Gate 4 — Audit-evidence retention policy exists and is correct . . . 19
Gate 5 — Control-support DLP policy exists in SIMULATION mode . . . 20
Gate 6 — DLP simulation is detecting the expected (benign) matches . . . 20
Gate 7 — AC/SC label & encryption evidence is present . . . 20
Gate 8 — Per-family evidence validation is green . . . 20
Gate 9 — Control-evidence report generates and artifacts attach . . . 20
Gate 10 — (On expand) enforcement is live and drift-monitored . . . 21
Evidence to retain . . . 21
6. Troubleshooting — Microsoft Purview NIST 800-53 Compliance Program 21
The NIST SP 800-53 template isn't listed / can't be added in Compliance Manager . . . 21
`CMPNIST-Scope.ps1` reports a plan is missing but you believe you have E5 . . . 22
Discovery shows no DLP policies, but you know some exist . . . 22
DLP policy created but it's blocking users during validation . . . 22
DLP simulation shows no matches for content you expect it to catch . . . 22
AU evidence is empty for the assessment window . . . 22
Audit-retention policy create fails on duration or priority . . . 23
Retention-policy / DLP cmdlet "term not recognized" . . . 23
Validation is red for a family you consider covered elsewhere . . . 23
Compliance Manager score didn't move after configuring a control . . . 23
Assessor says the evidence is insufficient . . . 23
When to escalate beyond this solution . . . 24
7. Best Practices — A Maintained NIST 800-53 Program in Microsoft Purview 24
Keep the authorization boundary bright . . . 24
Evidence is an artifact, not an assertion . . . 24

Configure audit before you need it . . . 25
Pilot high-impact controls in simulation — always . . . 25
Least-privilege roles and separation of duties (AC-5) . . . 25
Map to the tailored baseline, not the full catalog . . . 25
Treat the template and portal as evolving . . . 25
Corroborate and cross-reference . . . 26
Maintain, don't re-project . . . 26
8. Deliverables Summary — Microsoft Purview NIST 800-53 Compliance Program 26
Documentation . . . 26
PowerShell tools (5) . . . 27
Named artifacts created . . . 28
Definition of done . . . 28
Appendix A — PowerShell Scripts 30

# Executive Summary — Microsoft Purview NIST 800-53 Compliance Program

## The problem

NIST SP 800-53 arrives as a catalog of controls that someone must **map to what the tenant actually does**, **configure where there's a gap**, and **evidence** so an assessor can see the control is real. Too often the answer to "how do you meet AU-2 / SC-28 / MP-7?" is a slide, not a policy object and an audit record. Left unaddressed, that's both a compliance gap and a data-risk exposure — and audit-based evidence is **not retroactive**, so the window to capture it closes quietly.

## The solution

A complete, self-guided **NIST 800-53-aligned program inside Microsoft Purview**. It creates the assessment in **Compliance Manager** from the **NIST SP 800-53 Rev. 5** template, **maps each relevant control family to the Purview capability that implements it** — Audit (AU), DLP (SC/MP/SI), sensitivity labels & encryption (AC/SC), retention/records, and DSPM — **configures the supporting controls** (piloted in **simulation/test** first), and produces a **control-to-evidence report** the assessment package can cite. Five safe-by-default PowerShell tools (read-only or `-WhatIf`/simulation until you commit) do the scope check, posture discovery, configuration, per-family validation, and evidence reporting.

## What you get

- **A concrete control-to-Purview map** — which family each Purview capability satisfies, and which controls

are non-technical and deferred to your program (honest coverage, not overstated).

- **The AU foundation** — unified audit logging on and an audit-evidence retention policy, so accountability

evidence exists across the assessment window.

- **A configured SC/MP control** — a DLP policy created **in simulation** that evidences detection without

blocking users, then promoted to enforce after the pilot passes.

- **Access/protection evidence** — sensitivity-label encryption and usage rights referenced for AC-3/SC-28.

- **A defensible evidence package** — a family-to-artifact report plus the concrete artifacts attached to

Compliance Manager improvement actions, kept current by a scheduled read-only monitoring chain.

## Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand (enforce)** — configuring high-impact controls **in simulation/test on a limited pilot** before any tenant-wide enforcement, with pass/fail gates and documented rollback at every step.

## Boundaries

This solution provides the technical control configuration and the evidence. **Control applicability/tailoring, evidence sufficiency, residual-risk acceptance, the authorization boundary, and the authorization determination (ATO) are deferred to your Authorizing Official, security, compliance, records, privacy, and legal functions.** Microsoft Purview implements a **subset** of NIST 800-53 — physical, personnel, awareness, and much of incident response are organizational. Capabilities are **licensing-/plan-dependent** (the NIST premium template, advanced DLP, and DSPM require E5 / E5 Compliance) and the portal and templates are **actively evolving** — availability and paths are cited or flagged **"verify your licensing/tenant,"** never assumed.

## The bottom line

A NIST 800-53-aligned Purview program — controls mapped, configured, piloted in simulation, validated, and evidenced — so the capability is **in place and defensible**, and the authorization decision that follows rests on real artifacts instead of assertions.

# 1. Solution Overview — Microsoft Purview NIST 800-53 Compliance Program

## What this solution is

NIST SP 800-53 obligations arrive as a catalog of controls — access control, audit and accountability, media protection, system and communications protection, and more — that someone must **map to what your tenant actually does**, **configure where there's a gap**, and **evidence** so an assessor can see the control is real. Too many organizations answer "how do you meet AU-2 / SC-28 / MP-7?" with a slide instead of a policy object and an audit record. This solution stands up a **NIST 800-53-aligned program inside Microsoft Purview**: it builds the assessment in **Microsoft Purview Compliance Manager** from the **NIST SP 800-53 Rev. 5** template, **maps each relevant control family to the Purview capability that implements it** (Audit, DLP, sensitivity labels, retention/records, DSPM), **configures the supporting controls** — piloted in **simulation/test** mode first — and produces a **control-to-evidence report** the assessment package can cite. It uses only the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), **Exchange Online PowerShell**, and **Microsoft Graph** — no third-party tooling.

## What it does — and does not — decide

- **It delivers** the technical control mapping, the configured Purview controls, and the audit/assessment evidence: the *how*.
- **It does not make the authorization determination.** Whether the system is **authorized to operate**, the **authorization boundary**, the acceptance of **residual risk**, control **tailoring/applicability**, and the **retention/records/legal** schedule are decisions for your **Authorizing Official (AO), security, compliance, records, privacy, and legal** functions under your Risk Management Framework (RMF).

Purview supplies the evidence and the configured control; the **authorization and applicability determinations are deferred** to those functions. This boundary is stated in every document.

## Why this matters

• **Assessors ask for control implementation, not intent.** A NIST 800-53 assessment tests whether a control

is *implemented, documented, and evidenced*. A published DLP policy, a sensitivity label with encryption, an audit retention policy, and a Compliance Manager improvement action with an uploaded artifact are concrete implementation — a policy statement alone is not.

• **Purview implements a large slice of the technical families.** Microsoft's Compliance Manager NIST SP

800-53 template ships the control set and improvement actions; the underlying controls are delivered by Purview **Audit** (AU), **DLP** (SC/MP/SI), **sensitivity labels & encryption** (AC/SC/MP), **data lifecycle & records** (AU/SI/retention), and **DSPM** (RA/CA visibility). Getting them mapped and configured once turns a recurring scramble into a maintained program.

• **The controls are licensing-dependent and the portal evolves.** The Compliance Manager **premium

templates **(including NIST 800-53), advanced DLP, auto-labeling, and DSPM require** Microsoft 365 E5 **or the** E5 Compliance **add-on; Compliance Manager's improvement-action count and the portal paths change over time. This solution** cites or flags "verify your licensing/tenant"** — it does not assert a capability you may not have.

## How it works

1. **Assess (map).** Confirm licensing and roles, create the `NIST 800-53 – Rev5 – Assessment` in

Compliance Manager from the NIST SP 800-53 Rev. 5 template, and inventory the Purview controls already in place (audit state, DLP policies, published labels, retention policies) so you can see, per control family, what exists and what's a gap.

1. **Design (control-to-Purview map).** Record the `NIST 800-53 – Control-to-Purview – Map` — which

control family each Purview capability satisfies, and which controls are **not** technical (deferred to process/AO). Agree the **pilot scope** `NIST Pilot – Control Set – Stage1`.

1. **Configure (pilot in simulation/test).** Where a supporting control is missing, create it **safe-first**:

DLP policies in **simulation/test mode**, sensitivity/retention objects in a limited scope, audit retention enabled — every change previewed under `-WhatIf` and committed only with `-Commit`.

1. **Validate.** Run the validation scorecard: for each mapped control family, confirm the Purview evidence

exists (audit on, the DLP policy present, labels published, retention configured, the assessment created).

1. **Evidence & report.** Produce `NIST 800-53 – Control Evidence – Report` — the control-family-to-Purview

artifact map with status — and attach the concrete artifacts (policy exports, audit configuration, Compliance Manager improvement-action evidence) to the assessment package. The **authorization determination on that package is the AO's**, not ours.

1. **Expand & maintain.** Once the pilot passes, move DLP from simulation to enforce, extend scope, and

schedule the read-only Discovery→Validate→Report chain so control drift is caught and the evidence stays current between assessments.

## The control families this solution addresses in Purview

| NIST 800-53 family | Purview capability that supports it | Notes |
|---|---|---|
| **AU — Audit & Accountability** | Purview **Audit** (unified audit log, mailbox auditing, audit retention policies) | Audit is not retroactive — enable early. |
| **AC — Access Control** | **Sensitivity labels** (encryption/usage rights), DLP sharing controls | Identity/Conditional Access controls live in **Entra**, not Purview — noted, not claimed. |
| **SC — System & Communications Protection** | Sensitivity-label **encryption**, **message encryption**, DLP | SC-8/SC-28 protection of data in transit/at rest. |
| **MP — Media Protection** | **Endpoint/removable-media DLP**, labels | MP-7 restrict removable media. |
| **SI — System & Information Integrity** | **DLP** monitoring, **DSPM** posture | Detection/alerting evidence. |
| **CA / RA — Assessment / Risk** | **Compliance Manager** assessment + **DSPM** | CA/RA visibility; **authorization = AO decision (deferred)**. |
| **CM / PL / PM — Config / Planning / Program** | Compliance Manager improvement actions & program record | Program governance evidence. |
| **AT, IR, PS, PE, others** | Largely **process/organizational** | Mostly **deferred** to your program; Purview supplies partial technical evidence only. |

> *Purview does **not** implement every NIST 800-53 control — many are physical, personnel, or procedural. The map is explicit about which families Purview covers technically and which are deferred to your program. **Verify current family/template coverage against Microsoft documentation and your licensing.***

## What you can control

- Which control families are **in scope** for the Purview program and which are handled by process.
- Which supporting Purview controls to configure, and their **simulation** → **enforce** progression.
- The **pilot scope** validated before any tenant-wide enforcement.

• The **evidence set** attached to the assessment package (policy exports, audit config, improvement-action

artifacts).

## Limitations (be honest with buyers)

• **The authorization/ATO determination is not ours.** This solution configures and evidences controls;

**whether the system is authorized, the boundary, residual-risk acceptance, and control applicability are the AO's / security's / legal's decisions — deferred.**

• **Purview covers a subset of NIST 800-53.** Physical (PE), personnel (PS), awareness (AT), and much of IR

are organizational; Purview provides partial or no technical evidence for them. Don't represent Purview as full 800-53 coverage.

• **Premium features are license-gated.** The Compliance Manager NIST 800-53 **premium template**, advanced

DLP, auto-labeling, and DSPM require **E5 / E5 Compliance**. **Verify your licensing/tenant.**

• **Compliance Manager is primarily portal-driven.** Assessment creation, improvement-action evidence upload,

and score are done in the **Purview portal**; the scripts inventory and validate the **underlying Purview controls** (audit, DLP, labels, retention, roles) that supply the evidence — they do not invent a Compliance Manager cmdlet. **Verify current Compliance Manager automation options for your tenant.**

• **Audit is not retroactive.** Audit-based control evidence (AU family) accrues from the enablement date

forward — enable it before, not during, an assessment.

• **The portal and templates evolve.** Control counts, improvement actions, and paths change; treat the map

as maintained, and verify against current Microsoft documentation.

## Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Framework/Family> – <Stage>` and reused verbatim across the docs, scripts, and portal:

| Artifact | Name |
|---|---|
| Compliance Manager assessment (NIST SP 800-53 Rev. 5 template) | `NIST 800-53 – Rev5 – Assessment` |
| Control-to-Purview mapping workbook | `NIST 800-53 – Control-to-Purview – Map` |
| Audit-evidence retention policy (AU family) | `Control Evidence – NIST AU – Audit Retention` |
| Control-support DLP policy (SC/MP, simulation-first) | `Control Evidence – NIST SC-MP – DLP (Simulation)` |

| Artifact | Name |
|---|---|
| Control-evidence report / package export | `NIST 800-53 – Control Evidence – Report` |
| Pilot scope | `NIST Pilot – Control Set – Stage1` |

### The standard deployment model

> *Assess what NIST 800-53 requires and what Purview already does → design the control-to-Purview map → configure the supporting controls → **pilot in simulation/test** on a limited scope → validate the evidence exists per family → expand to enforcement and maintain. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand (enforce).** The **authorization determination** on the resulting evidence is the **AO's** — deferred, by design.*

# 2. Requirements Guide — Microsoft Purview NIST 800-53 Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the NIST 800-53-specific detail.

> ***Licensing/tenant boundary.** The Compliance Manager **NIST SP 800-53 premium template**, advanced DLP, auto-labeling, and DSPM require **Microsoft 365 E5** or the **E5 Compliance** add-on. Portal paths, improvement-action counts, and template versions **evolve** — confirm the current template and your entitlements rather than assuming. Where this guide flags "verify your licensing/tenant," do so before relying on the feature. **Authorization boundary.** This solution provides the technical configuration and evidence. The **authorization determination (ATO), the authorization boundary, residual-risk acceptance, and control applicability/tailoring are deferred to your Authorizing Official, security, compliance, records, privacy, and legal functions.***

## 2.1 Compliance licensing for the NIST 800-53 template and supporting controls

**Description:** Compliance Manager's **NIST SP 800-53 Rev. 5** assessment is a **premium template** (beyond the default Data Protection Baseline) and the supporting controls (advanced/auto-labeling DLP, DSPM, Audit Premium retention) require **E5** or the **E5 Compliance** add-on. Premium-template packs may also be metered/licensed separately in your tenant. **Why:** The template and several supporting controls are plan-gated; without the right plan the template won't be addable and the controls won't be available (GR §1). **Verify:** M365 admin center → `Billing → Licenses`; in Purview, `Compliance Manager → Assessment templates` — confirm **NIST SP 800-53** is listable/addable. `CMPNIST-Scope.ps1` reads `subscribedSkus`/service plans via Graph and reports whether an E5/E5-Compliance-bearing plan is present. **Implement:** Assign/purchase E5 or E5 Compliance before adding the template; confirm premium-template availability for your licensing.

## 2.2 Purview roles (least-privilege) for Compliance Manager and the supporting controls

**Description: Compliance Manager** uses its own role groups (**Compliance Manager Administrator / Assessor / Contributor / Reader**). Configuring the supporting controls needs **Compliance Administrator** or **Compliance Data Administrator**, plus the capability-specific roles: **Information Protection** (labels), the **DLP** roles, **Records Management**, and **Audit** roles. Reserve Global Administrator for one-time enablement only. **Why:** Purview uses fine-grained role groups; assessment work, DLP, labels, retention, and audit each need the matching role (GR §2). Separation of duties is itself a NIST control (AC-5). **Verify:** Purview portal → `Settings → Roles & scopes / Permissions` — confirm membership. `CMPNIST-Scope.ps1` attempts the read operations and reports which endpoints/roles are accessible. **Implement:** Assign the least-privilege role groups under change control; give assessors **Compliance Manager Reader/Assessor**, the configuring admin the capability roles, keeping duties separated.

## 2.3 Security & Compliance PowerShell + Exchange Online PowerShell + Graph

**Description:** The `ExchangeOnlineManagement` module provides `Connect-IPPSSession` (Security & Compliance PowerShell — DLP, labels, retention, `*-UnifiedAuditLogRetentionPolicy`) and `Connect-ExchangeOnline` (`Get/Set-AdminAuditLogConfig`, mailbox audit). `Microsoft.Graph` is used for licensing/role reads. **Why:** The supporting-control inventory and configuration run through these endpoints; the scripts use the right one for each task (GR §3). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement`; `Connect-IPPSSession`, `Connect-ExchangeOnline`, and `Connect-MgGraph` all succeed with a modern-auth/MFA admin. `CMPNIST-Scope.ps1` reports which endpoints are reachable. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; `Install-Module Microsoft.Graph -Scope CurrentUser`.

## 2.4 In-scope system boundary, data, and workloads (from the security/AO function)

**Description:** A documented statement of the **system/authorization boundary** the 800-53 assessment covers — the in-scope workloads (Exchange, SharePoint, OneDrive, Teams, endpoints) and the **information types / impact level** (e.g. moderate/high) that drive which controls and labels apply. **Why:** NIST control applicability and the label/DLP/retention design key off the boundary and impact level; these are **AO/security determinations**, not technical defaults (GR §4, §5). **Verify:** You can name the authorization boundary, the in-scope workloads, and the impact level, with named approvers. **Implement:** Capture the boundary, impact level, and in-scope data from the security/AO function before mapping controls. **The boundary determination is deferred to them.**

## 2.5 Control applicability / tailoring baseline (deferred to compliance/security)

**Description:** The **tailored control baseline** — which 800-53 controls (and which control enhancements) apply at your impact level, and any tailoring/inheritance decisions. **Why:** Not every control applies, and Purview only implements a subset; the map must record which controls are in scope, which Purview

covers, and which are deferred to process. **Applicability is a governance determination** (GR §5). **Verify:** You have the tailored baseline (or the relevant overlay) and named approvers; you can identify the technical families Purview will support. **Implement:** Obtain the tailored baseline from compliance/security before building the control-to-Purview map. **The applicability/tailoring determination is deferred to them.**

### 2.6 Unified audit logging and audit-evidence retention requirements (AU family)

**Description:** For the **AU** family, unified audit logging must be **on** and an audit-log **retention requirement** (how long which events are kept) must be defined by compliance/records — the solution configures `Control Evidence – NIST AU – Audit Retention` to it. **Why:** AU-2/AU-6/AU-11 evidence only exists if logging is on and retained; audit is **not retroactive** (GR §6 change discipline). Retention duration is a records determination, not a technical default. **Verify:** `Get-AdminAuditLogConfig | FL UnifiedAuditLogIngestionEnabled` (should be `True`); a documented retention requirement per event class exists. `CMPNIST-Discovery.ps1` reports logging state and existing retention policies. **Implement:** Enable ingestion under change control (`Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true`); capture the retention requirement. **The retention-schedule adequacy is deferred to compliance/records.**

### 2.7 A pilot scope and change control (simulation/test first)

**Description:** A limited **pilot** — a bounded user/site set and the supporting DLP policy in **simulation/test mode** — to validate before tenant-wide enforcement, plus an agreed change window (GR §6). Purview DLP supports a **test/simulation mode** that MUST be used before enforce. **Why:** DLP, label, and retention changes are high-impact; validate them small and in simulation first. **Verify:** A named pilot scope (`NIST Pilot – Control Set – Stage1`), that DLP simulation mode is available, and a change approval exist. **Implement:** Define the pilot scope and change window; keep new DLP policies in simulation until validated.

### 2.8 Evidence-handling and assessment-package requirements (from the assessor/AO)

**Description:** How control evidence must be **collected, formatted, and retained** for the assessment package (e.g. improvement-action artifacts in Compliance Manager, policy exports, audit-config snapshots), and who signs off. **Why:** The assessor/AO consumes the evidence; the format and retention are their requirement. The solution produces the artifacts; it does not judge sufficiency. **Verify:** You can name the evidence format, the retention for evidence, and the assessor/AO approvers. **Implement:** Capture the evidence requirements before generating `NIST 800-53 – Control Evidence – Report`. **Evidence sufficiency and the authorization decision are deferred to the assessor/AO.**

## Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a

solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

## 1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

## 2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

## 3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.

- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

## 4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

## 5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

## 6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant

governance functions.*

# 3. Implementation Guide — Microsoft Purview NIST 800-53 Compliance Program

Follow these steps **in order**. Configuration uses the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession` — DLP, labels, retention, `*-UnifiedAuditLogRetentionPolicy`), **Exchange Online PowerShell** (`Connect-ExchangeOnline` — `Get/Set-AdminAuditLogConfig`, mailbox audit), and **Microsoft Graph** (licensing/roles). Every write is gated: scripts run **read-only or `-WhatIf`/simulation by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Framework/Family> – <Stage>` convention from the Overview and are reused verbatim.

> ***Model:*** *Assess what 800-53 requires and what Purview already does, design the control-to-Purview map, configure the supporting controls,* ***pilot in simulation/test*** *on a limited scope, validate the evidence exists per family, then expand to enforcement. Pattern:* ***Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce). The authorization determination on the resulting evidence is the AO's — deferred. Audit is not retroactive*** *— enable AU evidence before the assessment window, not during it.*

## Step 1 — Assess licensing, roles, and current Purview control posture (Assess)

1. Run `CMPNIST-Scope.ps1` (read-only). It confirms connectivity to S&C PowerShell, Exchange Online, and

Graph, checks that an **E5 / E5 Compliance**-bearing plan is present (Requirement 2.1), and reports which role-gated read operations succeed (Requirement 2.2).

1. Run `CMPNIST-Discovery.ps1` (read-only). It inventories the Purview controls that back the NIST families:

• **AU** — `UnifiedAuditLogIngestionEnabled`, org mailbox auditing, existing audit-log retention policies;

• **SC/MP/SI** — existing **DLP policies** (`Get-DlpCompliancePolicy`) and their **mode** (Enable / Test);

• **AC/SC** — published **sensitivity labels** and label policies (`Get-Label`, `Get-LabelPolicy`);

• **retention** — retention policies/labels (`Get-RetentionCompliancePolicy`).

1. In the Purview portal, confirm **Compliance Manager** is visible and the **NIST SP 800-53** template is

listable under `Compliance Manager → Assessment templates` (visibility depends on role + licensing — Requirements 2.1/2.2). **Pass gate:** you have a written current-state per control family — what exists, what mode it's in, and what's a gap.

## Step 2 — Create the Compliance Manager assessment (Assess → Design)

1. In the Purview portal → **Compliance Manager** → **Assessments** → **Add assessment**, create

`NIST 800-53 – Rev5 – Assessment` from the **NIST SP 800-53 Rev. 5** template, scoped to the in-scope product/group (Requirement 2.4). *(Assessment creation and improvement-action evidence are portal operations — verify current Compliance Manager automation options for your tenant; the scripts inventory and validate the underlying controls, they do not create the assessment.)*

1. Review the improvement actions the template surfaces and note which are **Microsoft-managed** vs **your

controls **— you evidence the latter.** Pass gate:** the assessment exists and its improvement actions are visible with an initial score.

## Step 3 — Build the control-to-Purview map (Design)

1. With your compliance/security stakeholders and the **tailored baseline** (Requirement 2.5), record

`NIST 800-53 – Control-to-Purview – Map`: for each in-scope family, the Purview capability that implements it and the concrete artifact that will evidence it. Baseline mapping:

- **AU** → Purview **Audit** + `Control Evidence – NIST AU – Audit Retention`.
- **SC-8 / SC-28 (protect data in transit/at rest)** → **sensitivity-label encryption** + **message

encryption** + `Control Evidence – NIST SC-MP – DLP (Simulation)`.

- **MP-7 (media protection)** → **endpoint/removable-media DLP** (same policy or a dedicated one).
- **AC-3 / AC-6 (access enforcement / least privilege)** → **label-based encryption & usage rights** and

**DLP sharing restrictions** (note: identity/Conditional Access is **Entra**, recorded as inherited).

- **SI-4 (monitoring)** → **DLP** alerts + **DSPM** posture.
- **CA / RA** → the Compliance Manager **assessment** + **DSPM** (visibility; **authorization deferred**).
- **CM / PL / PM** → Compliance Manager improvement actions & program record.

1. Explicitly list the families Purview **does not** cover technically (PE, PS, AT, most of IR) as **deferred

to your program** — the map must be honest about coverage.

1. Define the **pilot scope** `NIST Pilot – Control Set – Stage1` (Requirement 2.7). **Pass gate:** the map is

documented and approved, with each in-scope control marked *Purview-covered* or *deferred*.

## Step 4 — Configure the AU family: audit + audit-evidence retention (Configure)

1. If Step 1 showed unified audit **off**, enable it under change control:

`CMPNIST-Set-ControlPolicy.ps1 -EnableUnifiedAudit -WhatIf` → review → re-run with `-Commit`. (Runs `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true`; activation can take time; not retroactive.)

1. Create the audit-evidence retention policy to the compliance/records requirement (Requirement 2.6):

```
CMPNIST-Set-ControlPolicy.ps1 -AuditRetentionName "Control Evidence – NIST AU – Audit Retention" -RecordTypes
```

`AzureActiveDirectory,ExchangeItem,SharePointFileOperation -Duration OneYear -Priority 100 -WhatIf` → review the exact `New-UnifiedAuditLogRetentionPolicy` → `-Commit`. **Verify accepted** `RetentionDuration` **values + licensing** before committing.

1. **Pass gate:** `CMPNIST-Discovery.ps1` shows ingestion `True` and the AU retention policy present with the

agreed duration. **Rollback:** enabling audit is non-destructive; remove the retention policy with `CMPNIST-Set-ControlPolicy.ps1 -AuditRetentionName "…" -Remove -Commit`.

## Step 5 — Configure the SC/MP/SI supporting DLP control in SIMULATION (Configure → Pilot)

1. Create the control-support DLP policy **in simulation/test mode** (never straight to enforce):

`CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence – NIST SC-MP – DLP (Simulation)" -Workloads Exchange,SharePoint,OneDrive,Endpoint -PilotGroup "NIST Pilot – Control Set – Stage1" -WhatIf` → review the exact `New-DlpCompliancePolicy -Mode TestWithoutNotifications` + `New-DlpComplianceRule` it would run → re-run with `-Commit`. The policy is created in **test mode** (`TestWithoutNotifications`), so it **detects and evidences without blocking** users.

1. Confirm the rule's sensitive-information / label conditions match your impact-level data (Requirement 2.4);

the determination of *which* information types apply is compliance/security's, not the script's.

1. **Pass gate:** `CMPNIST-Discovery.ps1` lists the DLP policy with `Mode = TestWithoutNotifications` scoped to

the pilot. **Rollback:** `CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "…" -Remove -Commit` (simulation policies are non-blocking; removal is clean).

## Step 6 — Configure the AC/SC label & encryption evidence (Configure)

1. Confirm at least one **sensitivity label with encryption/usage rights** is published to the pilot scope to

evidence AC-3/SC-28 (label taxonomy/design is a separate solution — here you confirm/reference it). If none exists, that gap is recorded in the map and handed to the labeling workstream.

1. Where message-level protection is required (SC-8), confirm **message encryption** is available/configured.

These are **portal/label** configurations; `CMPNIST-Discovery.ps1` reports published labels and label policies as evidence they exist. **Pass gate:** the labels/encryption that the map cites as AC/SC evidence are present and published to the pilot, or the gap is recorded and assigned.

## Step 7 — Validate control evidence exists per family (Validate)

1. Run `CMPNIST-Validate.ps1` (read-only). Against `NIST 800-53 – Control-to-Purview – Map`, it checks each

Purview-covered family has its evidence: audit on + AU retention present, the DLP policy present (and its mode), labels published, retention configured, and the assessment referenced. It emits a per-family **pass/fail** with the missing item named.

1. Resolve any red family (return to the relevant step). **Pass gate:** every Purview-covered family is green

for the pilot scope; every deferred family is explicitly marked deferred.

### Step 8 — Produce the control-evidence report / package (Validate → Evidence)

1. Run `CMPNIST-Report.ps1` to produce `NIST 800-53 – Control Evidence – Report` — the family-to-Purview

artifact map with status, exportable (CSV/HTML) for the assessment package.

1. Attach the concrete artifacts to the corresponding **Compliance Manager improvement actions** in the portal

(policy exports from Discovery, the audit-config snapshot, the DLP-policy definition, published-label list) per your evidence-handling requirement (Requirement 2.8). **Pass gate:** the report is generated and each Purview-covered control has an attached artifact. **The AO/assessor judges sufficiency and makes the authorization determination — deferred.**

### Step 9 — Expand to enforcement and maintain (Expand)

1. Once the pilot passes and the simulation DLP policy shows the expected (benign) detections, move it to

enforce under change control: `CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence – NIST SC-MP – DLP (Simulation)" -SetMode Enable -WhatIf` → review → `-Commit` (sets `-Mode Enable`). Consider renaming/annotating the policy to drop "(Simulation)" once enforcing, and extend scope beyond the pilot group.

1. Schedule the read-only chain (`CMPNIST-Discovery.ps1` → `CMPNIST-Validate.ps1` → `CMPNIST-Report.ps1`) on a

cadence so **control drift** — audit disabled, a DLP policy deleted or flipped to test, a label unpublished, a lapsed license — is caught between assessments and the evidence stays current.

1. Hand the map, the validation scorecard, and the evidence report to your compliance/security function as the

maintained program. **Pass gate:** enforcement is live for the agreed scope, the monitoring cadence is scheduled, and the evidence package is current. **Authorization remains the AO's decision.**

## 5. Testing & Validation — Microsoft Purview NIST 800-53 Compliance Program

Work through every gate. Each has a **method**, an **expected result (pass)**, and a **fail action**. Tests are read-only or use simulation/test-mode policies — no production data is altered and no user is blocked

during validation. Do not declare a family "evidenced" until its gate passes for the pilot scope, then re-confirm on expand.

> ***Remember:*** *these gates prove the* ***technical control is configured and evidenced*** *— they do* ***not*** *constitute an authorization.* ***Whether the evidence is sufficient and whether the system is authorized to operate are the assessor's / Authorizing Official's determinations — deferred.*** *Audit-based evidence is* ***not retroactive****.*

## Gate 1 — Licensing, roles, and toolchain are in place

- **Method:** `CMPNIST-Scope.ps1` — Graph licensing read, endpoint connectivity, role-gated read checks.
- **Pass:** an E5 / E5 Compliance-bearing plan is present; `Connect-IPPSSession`, `Connect-ExchangeOnline`,

and `Connect-MgGraph` succeed; the NIST SP 800-53 template is listable in Compliance Manager.

- **Fail:** assign the licensing (Requirement 2.1) / role group (2.2); install the modules (2.3); retest.

## Gate 2 — Compliance Manager NIST 800-53 assessment exists

- **Method:** Purview portal → `Compliance Manager → Assessments` — confirm `NIST 800-53 – Rev5 – Assessment`

from the NIST SP 800-53 Rev. 5 template, with improvement actions and an initial score.

- **Pass:** the assessment exists, scoped to the in-scope boundary, with improvement actions visible.
- **Fail:** create it (Implementation Step 2); confirm the premium template is licensed/available.

## Gate 3 — Unified audit logging on (AU family foundation)

- **Method:** `CMPNIST-Discovery.ps1`, or `Get-AdminAuditLogConfig | FL UnifiedAuditLogIngestionEnabled`.
- **Pass:** `UnifiedAuditLogIngestionEnabled = True` (org mailbox auditing on).
- **Fail:** enable via `CMPNIST-Set-ControlPolicy.ps1 -EnableUnifiedAudit -Commit` (Step 4); allow activation

time; note it is not retroactive; retest.

## Gate 4 — Audit-evidence retention policy exists and is correct

- **Method:** `CMPNIST-Discovery.ps1` retention section (`Get-UnifiedAuditLogRetentionPolicy`).
- **Pass:** `Control Evidence – NIST AU – Audit Retention` exists with the agreed duration and a unique

priority.

- **Fail:** create/correct with `CMPNIST-Set-ControlPolicy.ps1` (Step 4); verify the `RetentionDuration` value

and licensing.

## Gate 5 — Control-support DLP policy exists in SIMULATION mode

- **Method:** `CMPNIST-Discovery.ps1` DLP section (`Get-DlpCompliancePolicy` → `Mode`).
- **Pass:** `Control Evidence – NIST SC-MP – DLP (Simulation)` exists with `Mode = TestWithoutNotifications`,

scoped to `NIST Pilot – Control Set – Stage1` — detecting, **not blocking**.

- **Fail:** create it in simulation (Step 5, `-Commit`); confirm the workloads and pilot scope; retest.

## Gate 6 — DLP simulation is detecting the expected (benign) matches

- **Method:** in the Purview portal, open the DLP policy's **simulation/overview** and generate benign test

content matching the rule (e.g. a document with the in-scope information type) in the pilot scope; confirm the policy records matches without user impact.

- **Pass:** simulation shows matches for the test content; no user was blocked.
- **Fail:** confirm the rule's information-type/label conditions (Requirement 2.4) and pilot scope; allow for

policy-propagation latency before concluding.

## Gate 7 — AC/SC label & encryption evidence is present

- **Method:** `CMPNIST-Discovery.ps1` label section (`Get-Label`, `Get-LabelPolicy`).
- **Pass:** at least one sensitivity label with encryption/usage rights is published to the pilot (evidencing

AC-3/SC-28), or the gap is recorded in the map and assigned.

- **Fail:** publish/reference the label from the labeling workstream, or record the gap explicitly; retest.

## Gate 8 — Per-family evidence validation is green

- **Method:** `CMPNIST-Validate.ps1` against `NIST 800-53 – Control-to-Purview – Map`.
- **Pass:** every **Purview-covered** family reports its evidence present (audit + retention, DLP present +

mode, labels published, retention configured, assessment referenced); every **deferred** family is marked deferred.

- **Fail:** address the named missing item for the red family and re-run.

## Gate 9 — Control-evidence report generates and artifacts attach

- **Method:** `CMPNIST-Report.ps1` → `NIST 800-53 – Control Evidence – Report`; then attach artifacts to the

Compliance Manager improvement actions.

- **Pass:** the report generates with a row per in-scope family and status; each Purview-covered control has

an attached artifact per your evidence requirement (2.8).

- **Fail:** regenerate; attach the missing artifact; confirm evidence-handling requirements.

### Gate 10 — (On expand) enforcement is live and drift-monitored

- **Method:** after the pilot passes, `CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "…" -SetMode Enable -Commit`;

confirm `Mode = Enable`; confirm the scheduled Discovery→Validate→Report chain runs.

- **Pass:** the DLP control enforces for the agreed scope; the monitoring cadence catches drift.
- **Fail:** re-check the mode change and scope; schedule the read-only chain.

### Evidence to retain

- `CMPNIST-Scope.ps1`, `CMPNIST-Discovery.ps1`, and `CMPNIST-Validate.ps1` outputs (before/after).
- The `-WhatIf` transcripts for every audit-retention and DLP change (simulation → enforce).
- The DLP **simulation** results demonstrating detection without blocking.
- `NIST 800-53 – Control Evidence – Report` and the artifacts attached to each improvement action.
- The pilot scope and change approvals (Requirements 2.7/2.8).

> *Evidence **sufficiency**, control **applicability**, and the **authorization determination (ATO)** are **compliance/security/AO decisions** — these gates prove the technical configuration works and is evidenced, not that the control set is complete or the system is authorized.*

## 6. Troubleshooting — Microsoft Purview NIST 800-53 Compliance Program

The failure modes you'll hit building and maintaining a NIST 800-53 program in Purview. Each: **symptom** → **likely cause** → **fix.** Many "the control isn't there" reports are actually licensing, a DLP policy in the wrong mode, or evidence that was never attached — this guide separates those from real faults.

### The NIST SP 800-53 template isn't listed / can't be added in Compliance Manager

- **Cause A — licensing.** NIST 800-53 is a **premium template** requiring **E5 / E5 Compliance** (and premium

templates may be metered in your tenant). **Fix:** confirm the plan (`CMPNIST-Scope.ps1`); assign E5/E5 Compliance; check premium-template availability for your licensing (Requirement 2.1).

- **Cause B — role.** You lack **Compliance Manager Administrator**. **Fix:** assign the Compliance Manager

role group (Requirement 2.2). **Verify against current Microsoft documentation** — template names/versions change.

## `CMPNIST-Scope.ps1` reports a plan is missing but you believe you have E5

- **Cause:** the service-plan name checked (e.g. a compliance/DSPM plan) differs from what your tenant carries,

or the SKU is assigned but the specific service plan is disabled. **Fix:** treat the check as a **flag, not a verdict** — confirm in M365 admin center → `Billing → Licenses` and the Purview portal; plan names change, so **verify your licensing/tenant**.

## Discovery shows no DLP policies, but you know some exist

- **Cause A — endpoint/role.** Not connected to **Security & Compliance PowerShell** (`Connect-IPPSSession`),

or missing the DLP read role. **Fix:** confirm `Connect-IPPSSession` succeeded and the DLP/Compliance role is assigned (Requirement 2.2).

- **Cause B — scope.** Policies exist but outside the queried scope. **Fix:** re-run `CMPNIST-Discovery.ps1`

without scope filters to list all, then narrow.

## DLP policy created but it's blocking users during validation

- **Cause:** the policy was created (or flipped) to **Enable** (enforce) instead of simulation. During

validation it should be `TestWithoutNotifications` (simulation) — detect, don't block.

- **Fix:** confirm `Get-DlpCompliancePolicy | FL Name,Mode`; set it back to simulation

(`CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "…" -SetMode TestWithoutNotifications -Commit`) until the pilot passes, then promote to enforce deliberately (Step 9). Always preview with `-WhatIf` first.

## DLP simulation shows no matches for content you expect it to catch

- **Cause A — propagation latency.** New/changed DLP policies take time to propagate before they evaluate

content. **Fix:** allow time, then retest.

- **Cause B — condition mismatch.** The rule's sensitive-information-type or label condition doesn't match your

test content (or the information-type applicability was mis-scoped). **Fix:** review the rule conditions against your impact-level data (Requirement 2.4) — *which* information types apply is a compliance/security determination, adjust the rule to it. **Fix C — scope:** confirm the pilot group is actually in the policy location scope.

## AU evidence is empty for the assessment window

• **Cause:** unified audit logging was enabled **after** the activity, or wasn't on at all — **audit is not

retroactive**.** Fix:** enable it now (`CMPNIST-Set-ControlPolicy.ps1 -EnableUnifiedAudit -Commit`); evidence accrues from enablement forward. There is no way to recover events from before logging was on — capture this fact in the package rather than presenting a gap as compliance.

## Audit-retention policy create fails on duration or priority

• **Cause A — duration/licensing.** The `RetentionDuration` value isn't accepted for your plan, or a long-term

tier is requested without the add-on. **Fix:** verify accepted `RetentionDuration` values and licensing (Requirement 2.1) before `-Commit`.

• **Cause B — duplicate priority.** Priorities must be **unique**. **Fix:** pick an unused priority (lower =

evaluated first).

## Retention-policy / DLP cmdlet "term not recognized"

• **Cause:** wrong endpoint. `*-DlpCompliancePolicy`, `*-Label`, `*-RetentionCompliancePolicy`, and

`*-UnifiedAuditLogRetentionPolicy` are **Security & Compliance PowerShell** (`Connect-IPPSSession`); `Get/Set-AdminAuditLogConfig` is **Exchange Online** (`Connect-ExchangeOnline`). **Fix:** connect with the right endpoint for the task; both ship in `ExchangeOnlineManagement`.

## Validation is red for a family you consider covered elsewhere

• **Cause:** the control is implemented **outside Purview** (identity/Conditional Access in **Entra**, endpoint

config, physical) — Purview has no evidence to show for it. **Fix:** in `NIST 800-53 – Control-to-Purview – Map`, mark it **inherited/deferred** and point to the owning system; don't force Purview to "cover" it. The validator only checks Purview-covered families.

## Compliance Manager score didn't move after configuring a control

• **Cause:** the improvement action's **evidence/implementation status wasn't updated** in the portal, or the

test hasn't been marked. Compliance Manager scores off recorded improvement-action status, not off the raw tenant state. **Fix:** attach the artifact and set the improvement action's status in the portal (Requirement 2.8); scores update on the portal's cadence.

## Assessor says the evidence is insufficient

• **Cause:** evidence sufficiency is the **assessor's / AO's** determination, not the tool's. **Fix:** provide

the requested additional artifact (policy export, audit snapshot, screenshot) via `CMPNIST-Report.ps1` + Discovery outputs. **The sufficiency and authorization judgments are theirs — deferred** — the solution supplies artifacts, not the ruling.

## When to escalate beyond this solution

- **Control applicability/tailoring, residual-risk acceptance, the authorization boundary, or the ATO** →

**Authorizing Official / security / compliance / legal** (this solution configures and evidences; it does not authorize).

- **Retention-schedule adequacy or legal hold** → **compliance, records, privacy, and legal**.
- **Insider-risk / communication-compliance outcomes** (if used as SI/AU evidence) → **HR/legal** with

privacy-by-design and role separation; the solution provides the technical signal, not the case action.

- **Feature genuinely absent despite correct licensing** → verify against current Microsoft documentation and

open a Microsoft support case; Compliance Manager templates and Purview capabilities evolve.

# 7. Best Practices — A Maintained NIST 800-53 Program in Microsoft Purview

Operating principles for keeping a NIST SP 800-53-aligned Purview program accurate, evidenced, and defensible. Grounded in Microsoft's public guidance, NIST's Risk Management Framework, and the **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand (enforce)** model.

## Keep the authorization boundary bright

- **Configure and evidence the control; never assert the authorization.** Whether the system is authorized

to operate, the boundary, residual-risk acceptance, and control applicability are **AO/security/legal** decisions. Every artifact you produce is *input to* that decision, not the decision — say so in the package.

- **Map coverage honestly.** Purview implements a **subset** of 800-53 (mostly AU, AC, SC, MP, SI, and CA/RA

visibility). Physical, personnel, awareness, and much of IR are organizational. Mark deferred families **deferred** in `NIST 800-53 – Control-to-Purview – Map` — overstating coverage fails an assessment.

## Evidence is an artifact, not an assertion

- For every Purview-covered control, attach a **concrete artifact** to its Compliance Manager improvement

action: a policy export, an audit-config snapshot, a published-label list, a DLP-rule definition. "We have a policy" is not evidence; the policy object and its configuration are.

- Keep evidence **current between assessments** — a control that drifted since the last export is a finding.

The scheduled Discovery→Validate→Report chain keeps the package live, not stale.

## Configure audit before you need it

• **Audit is not retroactive** (AU family). Enable unified audit logging and the AU retention policy **now**,

so the accountability evidence exists across the assessment window. Every deferred day is permanently missing evidence.

• Set audit **retention by event class** to the compliance/records requirement — don't rely on the default,

and don't invent the duration. Verify accepted `RetentionDuration` values and the long-term tier's licensing.

## Pilot high-impact controls in simulation — always

• DLP, labels, and retention changes are tenant-impacting. Create DLP in **simulation/test mode**

(`TestWithoutNotifications`) first; it **evidences detection without blocking users**, which is exactly what you want during validation. Move to **enforce** (`-Mode Enable`) only after the pilot passes.

• Keep every change **reversible** and record the rollback (`-Remove`, `-SetMode`) with each change so a

questioned control can be backed out cleanly.

## Least-privilege roles and separation of duties (AC-5)

• Give assessors **Compliance Manager Reader/Assessor**; give the configuring admin the capability roles

(Information Protection, DLP, Records, Audit). Reserve Global Administrator for one-time enablement.

• Separation of duties is itself a control — the person who configures should not be the sole person who

attests. Review role membership periodically and log configuration changes.

## Map to the tailored baseline, not the full catalog

• Work from the **tailored baseline / overlay** for your impact level (Requirement 2.5), not the entire 800-53

catalog. Configure and evidence what applies; record inheritance (e.g. identity controls inherited from Entra/Conditional Access) rather than re-implementing it in Purview.

• Note **control enhancements** explicitly — a base control met without its required enhancement is a partial,

not a pass; the assessor decides.

## Treat the template and portal as evolving

• Compliance Manager's improvement-action count, the NIST template version, and portal paths change. **Verify

against current Microsoft documentation** rather than freezing a snapshot; re-baseline the map when the template updates.

• Confirm current **Compliance Manager automation** options for your tenant before standardizing on any API;

the scripts here inventory and validate the **underlying Purview controls**, which is the durable evidence layer regardless of portal changes.

### Corroborate and cross-reference

• One control often has evidence in more than one place — AU evidence in Purview Audit, monitoring evidence in

DLP alerts and DSPM, access evidence in labels *and* Entra. Cross-reference in the map so an assessor can follow the thread.

• Where a NIST family maps to a control implemented outside Purview (identity, endpoint config, physical),

**point to the owning system** in the map instead of claiming it.

### Maintain, don't re-project

• The program's value is that it's **maintained**: scheduled read-only Discovery/Validate/Report, drift caught

early, evidence refreshed, the map updated when scope or template changes. A one-time configuration decays; a maintained program passes the *next* assessment too.

## 8. Deliverables Summary — Microsoft Purview NIST 800-53 Compliance Program

What you receive, what to run, and what "done" looks like.

### Documentation

| Document | Purpose |
|---|---|
| **1. Solution Overview** | What a NIST 800-53 program in Purview is, the control-family-to-Purview map, what you control, honest coverage limits, the authorization boundary, and the naming convention. |
| **2. Requirements Guide** | NIST-specific prerequisites (premium-template licensing, Compliance Manager + capability roles, S&C/Exchange/Graph toolchain, system boundary, tailored baseline, audit/retention & evidence requirements, pilot) — each with Verify / Implement. |

| Document | Purpose |
|---|---|
| **3. Implementation Guide** | Ordered steps: assess posture, create the assessment, build the control-to-Purview map, configure AU audit + retention, configure the SC/MP DLP control **in simulation**, confirm AC/SC label evidence, validate per family, produce the evidence report, expand to enforce — pilot-first with pass/fail gates and rollback. |
| **5. Testing & Validation** | Ten gates from "licensing/roles in place" to "enforcement live and drift-monitored," each with method / pass / fail action. |
| **6. Troubleshooting** | The failure modes — template not addable, roles, DLP mode confusion, audit not retroactive, evidence gaps, endpoint mix-ups — and their fixes. |
| **7. Best Practices** | Program-maintenance principles: keep the authorization boundary bright, evidence as artifact, audit before you need it, pilot in simulation, least-privilege/SoD, tailored baseline, evolving template. |

## PowerShell tools (5)

All run **read-only or `-WhatIf`/simulation by default**; writes require `-Commit`. No credentials or secrets are embedded. DLP/label/retention cmdlets use **Security & Compliance PowerShell** (`Connect-IPPSSession`); audit enablement uses **Exchange Online PowerShell** (`Connect-ExchangeOnline`); licensing/roles use **Microsoft Graph**. The scripts inventory and validate the **underlying Purview controls** that evidence the NIST families — they do not invent a Compliance Manager cmdlet (assessment creation and improvement-action evidence are portal operations; verify current automation for your tenant).

| Script | Role | Default |
|---|---|---|
| `CMPNIST-Scope.ps1` | Assess/health: connectivity to S&C/Exchange/Graph, E5/E5-Compliance licensing check, role-gated read checks, in-scope family confirmation. | Read-only |
| `CMPNIST-Discovery.ps1` | Assess: inventory the Purview control posture per family — audit state + retention, DLP policies + mode, published labels, retention policies. | Read-only |

| Script | Role | Default |
|---|---|---|
| `CMPNIST-Set-ControlPolicy.ps1` | Configure/Remediate: enable unified audit; create/remove the AU audit-retention policy; create the SC/MP DLP control **in simulation** and later switch to enforce. | `-WhatIf` (writes on `-Commit`) |
| `CMPNIST-Validate.ps1` | Validate: per-family pass/fail against the control-to-Purview map (audit, retention, DLP present + mode, labels, assessment reference). | Read-only |
| `CMPNIST-Report.ps1` | Evidence: produce `NIST 800-53 – Control Evidence – Report` (family → Purview artifact → status) as CSV/HTML for the assessment package. | Read-only |

## Named artifacts created

- Compliance Manager assessment: `NIST 800-53 – Rev5 – Assessment` (portal, from the NIST SP 800-53 Rev. 5 template).
- Control-to-Purview mapping workbook: `NIST 800-53 – Control-to-Purview – Map`.
- Audit-evidence retention policy (AU): `Control Evidence – NIST AU – Audit Retention`.
- Control-support DLP policy (SC/MP, simulation-first): `Control Evidence – NIST SC-MP – DLP (Simulation)`.
- Evidence report / package export: `NIST 800-53 – Control Evidence – Report`.
- Pilot scope: `NIST Pilot – Control Set – Stage1`.

## Definition of done

- Licensing, roles, and toolchain confirmed; the **NIST SP 800-53 Rev. 5 assessment** created in Compliance

Manager.

- The **control-to-Purview map** documented and approved, each in-scope control marked *Purview-covered* or

*deferred*.

- **AU family:** unified audit logging **on** and `Control Evidence – NIST AU – Audit Retention` in place.
- **SC/MP:** `Control Evidence – NIST SC-MP – DLP (Simulation)` created in **test mode**, detecting without

blocking, validated on the pilot — then moved to **enforce** on expand.

- **AC/SC:** the label/encryption evidence the map cites is present (or the gap recorded and assigned).
- Per-family **validation green** for the pilot; `NIST 800-53 – Control Evidence – Report` generated and its

artifacts attached to the Compliance Manager improvement actions; the monitoring cadence scheduled.

> ***Boundary:*** *this solution delivers the technical control configuration and the evidence.* ***Control applicability/tailoring, evidence sufficiency, residual-risk acceptance, the authorization boundary, and the authorization determination (ATO) are deferred to your Authorizing Official, security, compliance, records, privacy, and legal functions.*** *Purview implements a* ***subset*** *of NIST 800-53; non-technical families are handled by your program. Feature availability is* ***licensing-/tenant-dependent and evolving — verify against your entitlements and current Microsoft documentation.***

# Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

## CMPNIST-Discovery.ps1

**Purpose:** Reports, with no changes, the Purview controls that supply NIST 800-53 evidence: unified-audit state and audit-log retention policies (AU); DLP policies and their MODE — Enable vs simulation (SC/MP/SI); published sensitivity labels and label policies (AC/SC); and retention policies. This is the current-state input to the control-to-Purview map. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPNIST-Discovery.ps1 Optional CSV of the DLP inventory: .\CMPNIST-Discovery.ps1 -CsvPath .\nist-purview-posture.csv Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS A per-family posture: UnifiedAuditLogIngestionEnabled True/False, the audit-retention policies, each DLP policy with its Mode (simulation policies show TestWithoutNotifications), the published labels/label policies, and the retention policies. Gaps are flagged for the map. .NOTES Purview category — NIST 800-53 program. Read-only. Compliance Manager assessment/score is a portal operation (not scripted here). Feature availability is licensing-/tenant-dependent and evolving. Authorization/applicability determinations are deferred to your AO/security/compliance/legal functions. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$CsvPath # optional: export the DLP inventory to CSV )

**How to run:** powershell -ExecutionPolicy Bypass -File .\CMPNIST-Discovery.ps1 Optional CSV of the DLP inventory: .\CMPNIST-Discovery.ps1 -CsvPath .\nist-purview-posture.csv Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS A per-family posture: UnifiedAuditLogIngestionEnabled True/False, the audit-retention policies, each DLP policy with its Mode (simulation policies show TestWithoutNotifications), the published labels/label policies, and the retention policies. Gaps are flagged for the map. .NOTES Purview category — NIST 800-53 program. Read-only. Compliance Manager assessment/score is a portal operation (not scripted here). Feature availability is licensing-/tenant-dependent and evolving. Authorization/applicability determinations are deferred to your AO/security/compliance/legal functions. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$CsvPath # optional: export the DLP inventory to CSV )

## CMPNIST-Report.ps1

**Purpose:** Read-only reporting. Assembles the control-evidence report for the assessment package: a row per in-scope NIST family with the Purview capability that implements it, the concrete artifact that evidences it, and the current status read live from the tenant (audit on, AU retention present, DLP policy + mode, labels published, retention present). Exports CSV and a simple HTML for the package. It reports state; it does not change anything and it does not authorize. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPNIST-Report.ps1 .\CMPNIST-Report.ps1 -CsvPath .\nist-evidence.csv -HtmlPath .\nist-evidence.html Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS NIST 800-53 – Control Evidence – Report generated with one row per family and a live status. Attach the concrete artifacts to the matching Compliance Manager improvement actions in the portal. .NOTES Purview category — NIST 800-53 program. Read-only. Evidence SUFFICIENCY and the AUTHORIZATION (ATO) are the assessor's / AO's determinations — DEFERRED. Compliance Manager scoring/attachment are portal operations. Feature availability is licensing-/tenant-dependent and evolving.

No cmdlets invented. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$AuditRetentionName = 'Control Evidence – NIST AU – Audit Retention', [string]$DlpPolicyName = 'Control Evidence – NIST SC-MP – DLP (Simulation)', [string]$CsvPath, [string]$HtmlPath )

**How to run:** powershell -ExecutionPolicy Bypass -File .\CMPNIST-Report.ps1 .\CMPNIST-Report.ps1 -CsvPath .\nist-evidence.csv -HtmlPath .\nist-evidence.html Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS NIST 800-53 – Control Evidence – Report generated with one row per family and a live status. Attach the concrete artifacts to the matching Compliance Manager improvement actions in the portal. .NOTES Purview category — NIST 800-53 program. Read-only. Evidence SUFFICIENCY and the AUTHORIZATION (ATO) are the assessor's / AO's determinations — DEFERRED. Compliance Manager scoring/attachment are portal operations. Feature availability is licensing-/tenant-dependent and evolving. No cmdlets invented. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$AuditRetentionName = 'Control Evidence – NIST AU – Audit Retention', [string]$DlpPolicyName = 'Control Evidence – NIST SC-MP – DLP (Simulation)', [string]$CsvPath, [string]$HtmlPath )

## CMPNIST-Scope.ps1

**Purpose:** Confirms you are ready to build the NIST 800-53 Purview program with no changes: connects to Security & Compliance PowerShell, Exchange Online, and Microsoft Graph; checks that an E5 / E5 Compliance-bearing plan is present (required for the NIST premium template, advanced DLP, DSPM); and probes the role-gated read operations so a missing permission surfaces early. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPNIST-Scope.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession + Connect-ExchangeOnline) and, for licensing, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: each endpoint reachable Yes/No, an E5/E5-Compliance-bearing plan present Yes/No (flagged, not asserted), and which role-gated reads (DLP, labels, retention, audit) succeed. Any licensing item is flagged "verify your licensing/tenant." .NOTES Purview category — NIST 800-53 program. Read-only. Feature availability is licensing-/tenant-dependent and evolving; confirm against your entitlements and current Microsoft documentation. Authorization determinations are deferred to your AO/security/compliance/legal functions. > [CmdletBinding()] param( [string]$UserPrincipalName, # optional admin UPN passed to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable )

**How to run:** powershell -ExecutionPolicy Bypass -File .\CMPNIST-Scope.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession + Connect-ExchangeOnline) and, for licensing, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A readiness summary: each endpoint reachable Yes/No, an E5/E5-Compliance-bearing plan present Yes/No (flagged, not asserted), and which role-gated reads (DLP, labels, retention, audit) succeed. Any licensing item is flagged "verify your licensing/tenant." .NOTES Purview category — NIST 800-53 program. Read-only. Feature availability is licensing-/tenant-dependent and evolving; confirm against your entitlements and current Microsoft documentation. Authorization determinations are deferred to your AO/security/compliance/legal functions. > [CmdletBinding()] param( [string]$UserPrincipalName, # optional admin UPN passed to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable )

## CMPNIST-Set-ControlPolicy.ps1

**Purpose:** Configuration/remediation helper for the supporting controls. Modes: -EnableUnifiedAudit ..... turns unified audit log ingestion on (AU foundation). -AuditRetentionName ..... creates/removes the AU audit-log retention policy. -DlpPolicyName (create) ..... creates the SC/MP control DLP policy IN SIMULATION (Mode = TestWithoutNotifications) — detects, does not block. -DlpPolicyName -SetMode <mode> .. changes an existing DLP policy's mode (e.g. promote to Enable). -Remove ..... removes the named audit-retention or DLP policy. SAFE BY DEFAULT: prints the exact cmdlet under -WhatIf and only writes with -Commit. New DLP policies are ALWAYS created in simulation; promotion to enforce is a separate, deliberate -SetMode. HOW TO RUN Enable unified audit (preview then commit): .\CMPNIST-Set-ControlPolicy.ps1 -EnableUnifiedAudit -WhatIf Create the AU audit-retention policy: .\CMPNIST-Set-ControlPolicy.ps1 -AuditRetentionName "Control Evidence - NIST AU - Audit Retention" `-RecordTypes AzureActiveDirectory,ExchangeItem,SharePointFileOperation -Duration OneYear -Priority 100 -WhatIf Create the SC/MP DLP control in simulation, scoped to the pilot: .\CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence - NIST SC-MP - DLP (Simulation)"` -Workloads Exchange,SharePoint,OneDrive,Endpoint -PilotGroup "NIST Pilot - Control Set - Stage1" -WhatIf Promote the DLP control to enforce after the pilot passes: .\CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence - NIST SC-MP - DLP (Simulation)" -SetMode Enable -WhatIf Enable uses Connect-ExchangeOnline; DLP/retention use Connect-IPPSSession. No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet(s) that would run. Under -Commit: the change is made and the object printed. New DLP always lands in TestWithoutNotifications (simulation). .NOTES Purview category — NIST 800-53 program. DLP/labels/retention changes are HIGH-IMPACT: pilot-in-simulation first. RetentionDuration/long-term tier are licensing-dependent — verify before -Commit. Authorization, applicability, and retention-schedule adequacy are deferred to your AO/security/compliance/records/legal. > [CmdletBinding()] param( --- AU: enable unified audit --- [switch]$EnableUnifiedAudit,

**How to run:** Enable unified audit (preview then commit): .\CMPNIST-Set-ControlPolicy.ps1 -EnableUnifiedAudit -WhatIf Create the AU audit-retention policy: .\CMPNIST-Set-ControlPolicy.ps1 -AuditRetentionName "Control Evidence - NIST AU - Audit Retention" `-RecordTypes AzureActiveDirectory,ExchangeItem,SharePointFileOperation -Duration OneYear -Priority 100 -WhatIf Create the SC/MP DLP control in simulation, scoped to the pilot: .\CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence - NIST SC-MP - DLP (Simulation)"` -Workloads Exchange,SharePoint,OneDrive,Endpoint -PilotGroup "NIST Pilot - Control Set - Stage1" -WhatIf Promote the DLP control to enforce after the pilot passes: .\CMPNIST-Set-ControlPolicy.ps1 -DlpPolicyName "Control Evidence - NIST SC-MP - DLP (Simulation)" -SetMode Enable -WhatIf Enable uses Connect-ExchangeOnline; DLP/retention use Connect-IPPSSession. No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet(s) that would run. Under -Commit: the change is made and the object printed. New DLP always lands in TestWithoutNotifications (simulation). .NOTES Purview category — NIST 800-53 program. DLP/labels/retention changes are HIGH-IMPACT: pilot-in-simulation first. RetentionDuration/long-term tier are licensing-dependent — verify before -Commit. Authorization, applicability, and retention-schedule adequacy are deferred to your AO/security/compliance/records/legal. > [CmdletBinding()] param( --- AU: enable unified audit --- [switch]$EnableUnifiedAudit,

## CMPNIST-Validate.ps1

**Purpose:** Read-only validation against NIST 800-53 – Control-to-Purview – Map. For each Purview-covered family it confirms the evidence exists: AU = unified audit on + the AU retention policy

present; SC/MP/SI = the control-support DLP policy present (and its mode reported); AC/SC = a published sensitivity label with encryption; retention = a retention policy present. Emits a per-family PASS / FAIL / DEFERRED line with the missing item named. Changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPNIST-Validate.ps1 .\CMPNIST-Validate.ps1 -CsvPath .\nist-validation.csv Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS Every Purview-covered family reports PASS with its evidence; deferred families are marked DEFERRED. A FAIL names the missing artifact so you can return to the matching Implementation step. .NOTES Purview category — NIST 800-53 program. Read-only. Whether the evidence is SUFFICIENT and whether the system is AUTHORIZED (ATO) are the assessor's / Authorizing Official's determinations — DEFERRED. This validates that the technical control is configured and evidenced, not that the control set is complete. Feature availability is licensing-/tenant-dependent and evolving. No cmdlets invented. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$AuditRetentionName = 'Control Evidence – NIST AU – Audit Retention', [string]$DlpPolicyName = 'Control Evidence – NIST SC-MP – DLP (Simulation)', [string]$CsvPath )

**How to run:** powershell -ExecutionPolicy Bypass -File .\CMPNIST-Validate.ps1 .\CMPNIST-Validate.ps1 -CsvPath .\nist-validation.csv Requires ExchangeOnlineManagement (Connect-IPPSSession + Connect-ExchangeOnline). Interactive modern-auth / MFA admin; no secrets in code. EXPECTED RESULTS Every Purview-covered family reports PASS with its evidence; deferred families are marked DEFERRED. A FAIL names the missing artifact so you can return to the matching Implementation step. .NOTES Purview category — NIST 800-53 program. Read-only. Whether the evidence is SUFFICIENT and whether the system is AUTHORIZED (ATO) are the assessor's / Authorizing Official's determinations — DEFERRED. This validates that the technical control is configured and evidenced, not that the control set is complete. Feature availability is licensing-/tenant-dependent and evolving. No cmdlets invented. > [CmdletBinding()] param( [string]$UserPrincipalName, [string]$AuditRetentionName = 'Control Evidence – NIST AU – Audit Retention', [string]$DlpPolicyName = 'Control Evidence – NIST SC-MP – DLP (Simulation)', [string]$CsvPath )